

Session Hijacking and its Impact on Authentication

Tool: Wireshark / Ettercap

Theory

Session hijacking involves intercepting network traffic to capture active session tokens or credentials transmitted over an unencrypted connection. Wireshark is a network protocol analyser used to capture and inspect packets in real time. Ettercap is a tool for man-in-the-middle attacks on a local network using ARP poisoning, which redirects traffic between two hosts through the attacker machine. This experiment is performed only within an isolated lab network on authorised VMs.

Steps

1. Start Kali Linux and Metasploitable 2 on a Host-Only network. Enable IP forwarding on Kali so traffic is relayed between hosts. Run: `echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward`
 2. Open Wireshark. Run: `sudo wireshark` — Select the network interface connected to the lab network, for example eth0, and click the blue shark fin icon to start capturing packets.
 3. Open a second terminal. Launch Ettercap in graphical mode. Run: `sudo ettercap -G`
 4. In Ettercap, go to Sniff menu and select Unified Sniffing. Select the network interface eth0 and click OK.
 5. Go to Hosts menu and select Scan for Hosts. Once complete, go to Hosts menu again and select Host List. The list shows all discovered hosts on the network.
 6. Select the gateway IP such as 192.168.56.1 and click Add to Target 1. Select the victim IP such as 192.168.56.102 and click Add to Target 2.
 7. Go to Mitm menu and select ARP Poisoning. Check the option Sniff remote connections and click OK. Then go to Start menu and select Start Sniffing.
 8. On the Metasploitable machine open a browser and access a plain HTTP page. Switch to Wireshark on Kali and apply the filter: `http` — Observe the captured HTTP traffic including any credentials or cookies visible in plain text in the packet details panel.
 9. To view a full HTTP session, right-click any HTTP packet in Wireshark and select Follow > TCP Stream. This reassembles the entire conversation including submitted form data. When finished, stop Ettercap by going to Start > Stop Sniffing and then Mitm > Stop Mitm Attack to restore normal ARP tables.
-

Conclusion

Wireshark and Ettercap demonstrated how unencrypted HTTP traffic on a local network can be intercepted using ARP poisoning, exposing session data and credentials in plain text. This confirms why HTTPS encryption is essential for all web applications to protect user sessions from interception.